EXECUTIVE SUMMARY

Elastic Enclave HSM for Enterprise Identity

HSM-grade key custody for EJBCA PKI and SPIRE zero-trust — autoscaled on commodity spot EC2.

One signer gateway becomes an elastic, **FIPS 140-3 Level 1 HSM** that serves ***both*** EJBCA certificate issuance ***and*** SPIRE workload identity from the same fleet. The CA/ICA signing key is released only into an attested Nitro Enclave via KMS and never leaves that boundary — the parent host and operators never see the plaintext key.

The problem

- **Cost of HA at scale —** An HA CloudHSM cluster bills 24/7 per HSM for peak capacity — expensive whether you sign 10 or 10,000 TPS.
- **No autoscaling —** Fixed capacity. You provision for peak and pay for it continuously; there is no scale-to-load.
- **No production post-quantum —** No ML-DSA / ML-KEM / hybrid signing in the firmware today.

The solution — four pillars

Pillar	What it means
Elastic — pay for load	No dedicated HSM. Spot EC2 + KMS, autoscale to min when idle. Linear scale-out: add boxes -> +throughput, behind a multi-AZ NLB.
HSM-grade custody (FIPS 140-3 L1)	The CA/ICA key is released only into an attested enclave via KMS and never leaves that boundary. Parent host and operators never see plaintext key.
PQC-native	ML-DSA-65, ML-KEM-768/1024 and hybrid (P-384+ML-DSA) signing — in software, today, not waiting on HSM firmware.
Enterprise resilience	Enclave-aware health reporting; a wedged enclave -> 503 -> NLB -> ASG auto-replaces. Self-heals under chaos, validated on real spot infra.

Proven throughput (measured on AWS)

Path	Measured throughput	Bottleneck
Raw signer ceiling (HSM primitive)	~8.6k signs/sec/box → ~48k fleet	never the bottleneck
EJBCA cert issuance	~895 certs/sec/node	EJBCA-bound, scales w/ nodes
SPIRE SVID issuance	~236 SVIDs/sec	server-bound, scales w/ servers

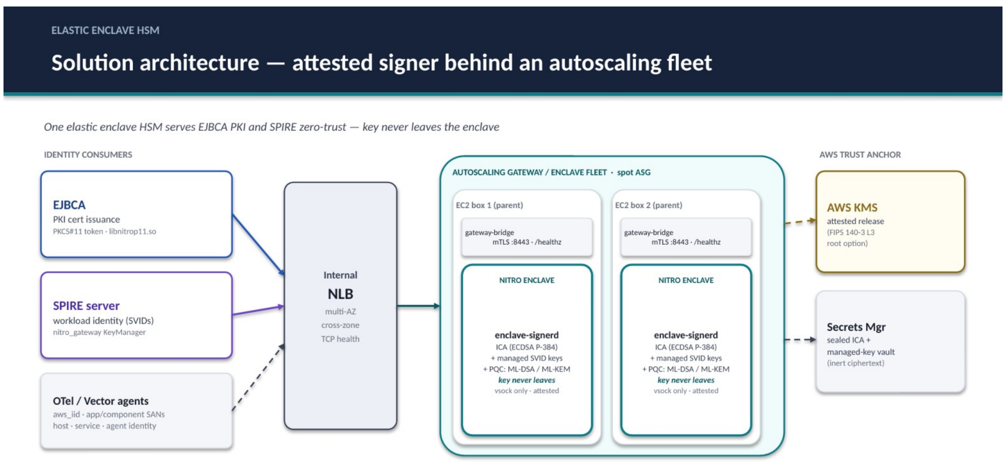
The signer carries ~10–36× headroom over both product paths — you scale EJBCA nodes and SPIRE servers, not the signer.

Zero-trust use case — OpenTelemetry agent auth

At deploy time each instance is tagged app and component; SPIRE's aws_iid node attestor reads those tags from the signed AWS Instance Identity Document and mints a SPIFFE ID whose SAN encodes identity at three levels — host/node, service/component, and agent/workload. Every SVID is signed inside the enclave, so OTel agents authenticate with a cryptographic identity that never leaves FIPS 140-3 L1 custody.

FIPS 140-3 posture

High-volume leaf and SVID signing runs at Level 1 inside the attested enclave — hardware-isolated, operator-inaccessible memory with cryptographic attestation of the exact image that may hold the key. An optional Level 3 root (KMS or CloudHSM) anchors the trust chain and signs the intermediate: buy L3 assurance once for the root, and scale L1 signing elastically.



Unified elastic enclave HSM — one attested signer behind an autoscaling fleet.

Bottom line: Adopt the elastic enclave HSM as the unified signing tier for EJBCA and SPIRE — it delivers HSM-grade, PQC-ready key custody at spot-EC2 economics, scales to load instead of to peak, and has been validated end-to-end on real AWS infrastructure.